API Security Framework: Automated BOLA Testing

Automates detection of **Broken Object Level Authorization (BOLA / IDOR)**, OWASP API Security Top 10 #1, by combining three layers:

Layer	Tool	What it does
1	Native Python check	User B requests User A's objects; flags 2xx responses and missing auth
2	Postman + Newman	Auto-generates a collection with assertions (expects 401/403/404 for non-owners) and runs it
3	OWASP ZAP	Imports your OpenAPI spec, spiders, active-scans, and tags access-control-related alerts

> **Note:** ZAP's scanner is generic and does not understand object ownership on its own. Layers 1 and 2 are what actually prove BOLA; ZAP adds broad coverage (injection, misconfig, etc.).

Setup

```
pip install -r requirements.txt
npm install -g newman                      # for layer 2
# Layer 3: run ZAP in daemon mode
docker run -u zap -p 8080:8080 zaproxy/zap-stable \
  zap.sh -daemon -host 0.0.0.0 -port 8080 -config api.key=$ZAP_API_KEY
```

Usage

```
python bola_framework.py init              # writes config.json
export ALICE_TOKEN=... BOB_TOKEN=... ZAP_API_KEY=...
python bola_framework.py run               # native + Newman
python bola_framework.py run --zap         # add ZAP scan
python bola_framework.py run --allow-unsafe  # include DELETE/PUT endpoints (test env only)
```

Config

Two or more test users with real tokens, plus endpoints where `owner` owns `resource_id`:

```
{
  "base_url": "https://staging.example.com",
  "users": {"alice": {"token": "${ALICE_TOKEN}"}, "bob": {"token": "${BOB_TOKEN}"}},
  "endpoints": [
    {"name": "Get order", "method": "GET", "path": "/orders/{id}",
     "owner": "alice", "resource_id": "1001"}
```

```
  ]
}
```

Endpoints marked `"safe": false` are skipped unless `--allow-unsafe` is passed.

Output

`reports/` contains `report.json`, `report.md`, the Postman collection and environment (importable into Postman), and `newman_report.json`.

The process exits with code **1** if any High finding exists, so it can gate a CI pipeline:

```
- run: python bola_framework.py run --zap
```

Interpreting results

- **High, cross-user object access:** a non-owner received the owner's data/action. Confirmed BOLA.
- **Medium:** a non-owner got a 2xx but the body differs; review manually.
- **High, missing authentication:** endpoint works with no token.

Safety

Only test systems you own or have written permission to test. Use a staging environment with dedicated test accounts.